



VoidLink: AI-Generated Malware

Description: CISA's uncertain future remains quite worrisome. Worrisome is Ireland's new "lawful" interception law. The EU's Digital Rights organization pushes back. Microsoft acknowledges it turns over user encryption keys. Alex Neihaus on AI enterprise usage dangers. Gavin confesses he put a database on the Internet. Worries about a massive podcast rewinding backlog. What does the emergence of AI-generated malware portend?

High quality (64 kbps) mp3 audio file URL: <http://media.GRC.com/sn/SN-1062.mp3>

Quarter size (16 kbps) mp3 audio file URL: <http://media.GRC.com/sn/sn-1062-lq.mp3>

SHOW TEASE: It's time for Security Now!. Steve Gibson is here. He's worried. He's worried about the future of CISA in the United States. He's worried about Ireland's new lawful interception law that makes spyware legal. He's worried about AI-generated malware. Yes, it's here. All that and more coming up next on Security Now!.

Leo Laporte: This is Security Now! with Steve Gibson, Episode 1062, recorded Tuesday, January 27th, 2026: VoidLink: AI-Generated Malware.

It's time for Security Now! the show we cover the latest security news, computer information that you need to know with this guy right here, the King of the Hill when it comes to security, Mr. Steve Gibson. Hi, Steve.

Steve Gibson: Leo, great to be with you again for another Tuesday, the last one of January. So say goodbye to January, everybody. I don't know where it went.

Leo: Be happy to let it go. I'm not attached.

Steve: Like I said, many people it was a bad January, from many perspectives, and certainly cold, also. I guess the weather has just gone crazy storm-wise, too.

Leo: Oh, man, are we freezing. Yeah, really freezing cold. It's only 52 degrees here in California. It's just terrible.

Steve: I don't know what to do.

Leo: All right. What are covering on the show today? Enough frivolity.

Steve: Check Point Research, I think they call themselves, Check Point Research, Check Point is how we know them, took a close look at what they recently discovered as the first very impressive and very concerning, purely AI-generated malware. Because the developer made the mistake, so not a rocket scientist here - or a security guy, kind of an anti-security guy, actually - of leaving a directory exposed. One of his server's directories was exposed. They were able to get literally an inside look at the production of an AI-generated malware. And there's some important takeaways from that which we're going to get to.

But first we're going to look at, unfortunately, CISA's uncertain future, which I kind of thought it had been resolved, but no. Our old friend Rand Paul has stuck his finger in this, and is going to maybe cause some trouble. We'll see. We've got a worrisome new law which has been passed in Ireland which we need to take a look at because for a while I actually had a working title for the podcast, Leo, was "The State Versus Encryption." And we're going to end up with a couple stories that are that, which is why the podcast carried that working title until I saw that really we need to talk about malware and AI. There is a group in the EU, the Digital Rights Organization, pushing back on some of what seems to be happening. So we're going to take a look at that.

I never had a chance to hear what you guys and Alex Stamos on Sunday were talking about relative to Microsoft's acknowledgment that it has turned over some encryption keys to the FBI. We're going to discuss that, and I have - again, I didn't hear what happened on Sunday. But I have maybe a surprising takeaway for our listeners relative to Microsoft. I try to be very fair. I know I'm very hard on them, like, most of the time. In this case, I take a different position.

Leo: Yeah, I think you and Alex may actually be on the same page. I'll let you know what he thought about it when we get to it, yeah.

Steve: Okay. Also, our old friend Alex Neihaus had some really useful and insightful feedback about AI enterprise usage and how it's fraught with some dangers. I want to share that with our listeners. Another listener, Gavin, confesses that he deliberately put a database on the Internet, and explains why. Oh, and there are some worries, Leo...

Leo: Uh-oh.

Steve: ...about the need to rewind podcasts and how there may be a massive backlog that is growing which we need to deal with. And then we're going to take a look at the emergence of - remember our DVD rewinder from last week.

Leo: Oh.

Steve: That's right.

Leo: You know, people have been leaving this show at the end and not rewinding it. I think this is a massive problem.

Steve: Really, you're not thinking about the next person; right? You're just saying thanks very much.

Leo: Next one's going to start at the end.

Steve: I took the last napkin; and, eff you, I don't care.

Leo: I always do that. Lisa yells at me because I'll leave this much milk in the carton, you know, put it back in the fridge. And it's very disappointing to her because...

Steve: And Leo, let's not even get into being married and toilet rolls.

Leo: Oh, yes.

Steve: That's, oh, that's not good.

Leo: Oh, yes. Oh, yes. Oh, yes.

Steve: And does it come off the front or the back? But anyway, that's a whole 'nother topic. We do have a Picture of the Week which we may get to someday. Do we have four ads? Or five? I didn't...

Leo: We have, I believe, three, which is for this show a dearth, a paucity of ads. But we will - I will pause. And sometimes, people might have noticed this, an ad will sneak in after the fact.

Steve: You are a cunning linguist. That's all I have to say.

Leo: So as far as I know, I will be reading three ads. Others may be inserted against your will.

Steve: Okay. So we're going to do our five pauses.

Leo: Yes, as always.

Steve: The pause that refreshes my whistle.

Leo: Always want to keep that whistle wetted. I've got a Picture of the Week.

Steve: And it's another popular one. It generated a lot of feedback, as these have been recently. I gave this one the title "This is what was once called 'Yankee Ingenuity.'"

Leo: Okay. Let me put it up on the big screen, and we can look at it together here. I'm going to scroll up. Yankee Ingenuity. Okay. You want to describe that?

Steve: So we don't really know what the back story is.

Leo: What's going on here?

Steve: But when we were growing up, we probably encountered, like, garden gates where you had a - it was a slider that slid into a mating capture retainer.

Leo: I'm sure there's a name. If you go to the hardware store, it's some sort of slide bolt or something, yeah.

Steve: Yeah. And so you would left the arm up, slide it over, then put it back down. And gravity would keep it rotated so that it would stay either locked open or locked closed. Anyway, I mean, it's meant for some barn; right? A barn door kind of thing. Well, apparently somebody's having some sort of problem with their gas cap cover of their car.

Leo: It's been popping open.

Steve: And what really impresses me, Leo, is they did not leave it looking like, you know, silver chrome.

Leo: Oh, no.

Steve: It's been body painted to match the car perfectly. So unless you were, I mean, if you were walking by it, you might miss the fact that they'd added a barn door closing lock to the outside of their gas cap cover. So one of our insightful listeners who received it, I got the email out, actually, early this week. They went out Sunday evening. Although Microsoft took it upon themselves to decide...

Leo: Oh, yeah.

Steve: ...that GRC was not trustworthy.

Leo: Oh, boy.

Steve: So 15,047 of the nearly 20,000, it's 19,800 and something, 15,047 were all blocked if they went to Outlook.com or Hotmail.com. When I saw that that had happened, I was able to collect them, and they went out with no trouble at all last night.

So it's like, okay, Microsoft, I guess maybe Sunday freaked you out? I don't know. Because normally I do them on Monday or Tuesday. Anyway. I mean, it just - some AI, you know, had a spasm, and so it's...

Leo: It's never going to stop, Steve. There'll always be a little bit of this here or there.

Steve: Yup.

Leo: I'm convinced. It's just, you know...

Steve: Yeah, well, the spammers are trying to look legitimate. And so there's a value judgment that's having to be made.

Leo: Right.

Steve: So any - in any event. This listener said, "Well, you know what that is?" I thought, no. He said, "That's two-factor authentication." You've got the inside, you have to pull the trigger to release the cap. And then you have to come around outside and use the second-factor to slide the bolt over in order to open the cap. I suspect what most of our listeners do, that the automatic cap closer holder broke. And so the cover was flapping in the breeze, and they said, hey, you know, we used to have a barn. We don't have it, but we do have the lock that used to keep the door closed.

Leo: They're probably patting themselves on the back because initially they used duct tape to hold it closed. And then they decided to really upgrade it with the slide bolt.

Steve: Which would explain the need to repaint the car in the same color, yes.

Leo: Exactly, yeah.

Steve: That would make sense. Okay. So I've said for years that I have been pleasantly surprised by the success and effectiveness of CISA. You know, it's been an amazing success, the Cybersecurity and Infrastructure Security Agency. Awkwardly named. But, boy, are they doing a great job. Since its creation 11 years ago, 2015, CISA has been a huge win for our nation's cybersecurity. You know, my default belief is that government has a difficult time getting out of its own way, way more often than not. So CISA was a welcome and actually well-needed exception to that. As this podcast has covered since its inception, they've been able to mandate that government agencies pay needed attention to many specific critical security problems that would otherwise have fallen through the cracks.

You know, the government agencies have better things to do than, oh, well, we really don't want to do an update. They'll have to have our network down for, you know, blah, blah, blah, whatever. And besides, nothing's happened yet. Right. And CISA's also been empowered to set deadlines which had to be honored. Their creation of KEV (K-E-V), the

Known Exploited Vulnerabilities catalog, was a brilliant means of focusing those always limited and readily, you know, distracted bureaucratic resources where they were needed.

And, yeah, it's true. 125 security things happened on the second Tuesday of the month. But it turns out that two of those are really critical, and CISA's been instrumental in saying, get to the other things when you can, but do these now because this really matters. So that's all been good news. The bad news is that CISA was not created to be a permanent entity. Sadly, the Constitution of the United States is completely silent regarding the need for a permanent cybersecurity watchdog agency within the federal government. I guess our forefathers were unable to foresee that. This means that politicians created CISA, and politicians are required to keep CISA funded and authorized.

Last week, The Record updated us on the state of CISA's continuation, writing: "Congressional leaders on Tuesday" - meaning last Tuesday - "released a compromise government funding bill that would, once again, temporarily extend the life of two key cybersecurity laws. The bipartisan legislation would reauthorize the 2015 Cybersecurity and Infrastructure Security Act (CISA)" - or Agency - "and the State and Local Cybersecurity Grant Program, pushing it through the end of September.

"The extension in the \$1.2 trillion" - that's the entire funding bill - "\$1.2 trillion is the latest short-term solution in a months-long saga for CISA 2015, which provides liability" - we've talked about this just last week - "crucial liability protections to encourage private companies to share digital threat information with the federal government." And as we've said, it's like they're not going to do it unless they have liability protection. The C-suite executives made that very clear.

The Record says: "Both statutes received widespread support from the cybersecurity community and the Trump administration prior to their expiration last year. They received temporary reprieves in the continuing resolution that reopened the government in November. The House did approve a bill to extend the grants effort, but there's been no action on the Senate side. Meanwhile, several proposals have been introduced to reauthorize the 2015 CISA long-term." Please, let that happen. Let's not make this another football that we keep kicking. This we need. And not having it has already, like, stalled, like there's now a gap that needs to be filled because industry went silent as soon as they lost their liability protections.

Anyway, The Record wrote: "The House Homeland Security Committee last year passed legislation to renew it for a decade" - thank you - "with minor updates, but it hasn't been scheduled for a floor vote. A bipartisan Senate duo introduced a bill that would extend the law for 10 years" - yes - "and provide retroactive protections for companies that shared cyber threat data even after the law lapsed. But," as I mentioned, The Record writes: "Senator Rand Paul, chair of the Senate Homeland Security Committee, has drafted a bill that would trash the legal protection outlined in the original statute." Well, thanks.

They wrote: "House leaders plan to hold a vote later in the week on the spending deal, which boosts defense funding to over \$839 billion. Lawmakers have 10 days to clear the package for President Donald Trump's signature before federal funding is set to lapse for the programs it covers. With the Senate in recess this week" - meaning last week - "the upper chamber will need to approve the legislation when they return next week" - meaning this week - "if Congress is going to head off another funding lapse and a partial government shutdown."

And as a total aside, there's a lot of conversation now that looks like we may be going into another shutdown over DHS and the reauthorization and increase in other aspects of the budget. So we'll see.

And I don't know what's up with Senator Rand Paul. He's always something of a wildcard, and pretty much a pain in everyone's butt. But after first being elected to the Senate in 2010 he's been reelected twice since, every six years. So he seems to be what his state of Kentucky wants in a Senator. Of course he shares that position with Mitch McConnell. But in this case it will be very bad if he gets his way. As, again, as we noted last week, the executives of the nation's private infrastructure agencies consider their vulnerability and breach disclosure protections to be critical and a crucial feature of this legislation. So much so that in the bills that are being talked about, protections are being made retroactive because they've said we need to have that. You asked us to keep talking to you after CISA lapsed, and we did, some of us. So you need to protect us from that.

Anyway, no one can make these executives disclose information which is privately held if they choose not to. So if the government wants to know what's going on, as it should, then protecting those who are voluntarily disclosing is the entire point of this aspect of the reauthorization. We should know in another week or two whether the politicians have now screwed up what had been a surprisingly well-designed and well-working system. As I said, when we talked about this 10 years ago on the podcast when it happened, it's like, oh, great, you know, another Homeland Security agency. Well, then we got surprised because it just - it was so effective and so useful. Of course, at the time it was really well managed. It was Chris Krebs who was - was he the original? I don't know if...

Leo: I don't know. He was the one who was fired because he said the election was secure in 2020.

Steve: Right. They looked very closely at the 2020 election, yeah.

Leo: Yeah.

Steve: So I would imagine he was because if that was 2020, and it was created in 2015, then it would have only been five years old at that point.

Leo: Yeah. We talked about this. Alex Stamos is a partner, of course, for a long time with Chris Krebs, yeah.

Steve: Right, right. Okay. So one of the reasons that the working title of the podcast until I got to the news about AI and malware was "The State Versus Encryption" is Ireland's new lawful - I just love this word, this phrase - "lawful interception law." Right? They can make whatever laws they want. So the first half of this next piece is the news that Ireland has just passed a new lawful interception law granting the government significant new powers. The short blurb that carried that news, the short blurb just said - this is all I first saw. It said: "The Irish government has passed a new lawful interception law. The new legislation grants law enforcement and intelligence agencies the power to surveil any type of modern communications channel. It also grants the agencies the right to use covert software for their operations, such as spyware."

Leo: Oh, great.

Steve: Uh-huh. It's not - you don't have to be ashamed or bashful or shy or pretend you're not doing it anymore. Now it's a law. Now it's legal. "The new law," this little blurb said, "will also require communication service providers to work closely and aid any government operation." Okay. So add this to the other recent news of pending and enacted legislation, you know, we're clearly witnessing, remember we talked last week about Germany. Basically we can't pronounce the name of the agency because it's got 25 letters in its name, most consonants. But they're doing the same thing. So we're seeing, we're witnessing an accelerating trend in governments legislating themselves sweeping rights to intercept, monitor, and eavesdrop upon pretty much anything they wish.

Okay. So this week we have similar legislation to what we talked about in Germany last week, which has passed. It was pending in Germany. Ireland passed this. So I scanned last Tuesday's press release from the Irish government, from which I'm going to excerpt two pieces, just two notable pieces. The first point talks about the clear need for an update to their very old law. I don't think anybody would argue with that because that was - the original law that's being updated by this legislation is from 1993. And, you know, need to update, that's noncontroversial. But point number two says that the new law includes "a clear statement of the general legal principle that lawful interception powers needed to address serious crime and security threats are applicable to all forms of communications." Sort of call this sweeping, you know, I don't know if, I mean, that's the right word for it; right?

They specifically write: "The Minister proposes" - and the language here is "proposes," but this law passed, just to be clear. "The Minister proposes an updated legal framework which is flexible and includes comprehensive principles, policies, and definitions to allow for lawful interception powers to be applied to any digital devices or services which can send or receive a communications message, for example, the 'Internet of things,' and email, and digital messaging devices and services.

"The legislation will provide for a clear statement - which is to say the legislation does provide a clear statement of general principle that lawful interception powers apply to all forms of communications, whether encrypted or not, and can be used to obtain either content data" - and they say (the substance of a communication) - or related 'metadata' (data that provide information about a communication but not its content, such as phone call or email time/date, sender/receiver of a communication, the geolocation of an electronic device, or the source and destination IP addresses)." But they're specifically also saying "and the content." And it says: "The legislation will also apply to parcel delivery services. The Minister's view," they write, "is that effective lawful interception powers can be accompanied by the necessary privacy, encryption, and digital security safeguards."

Leo: [Buzzer sound]

Steve: Because they're expert in this, Leo.

Leo: Yeah.

Steve: These legislators, they know their crypto.

Leo: Mmm-hmm.

Steve: It says: "In June 2025, the EU Commission published a 'Roadmap for lawful and effective access to data for law enforcement,' which stated that terrorism, organized crime, online fraud, drug trafficking, child sexual abuse" - we knew we were going to get to the kids - "online sexual extortion, ransomware, and many other crimes all leave digital traces. Around 85% of criminal investigations now rely on electronic evidence. Requests for data addressed to service providers tripled between 2017 and 2022, and the need for these data is constantly increasing." I love the fact that they treat the word "data" as plural. I always fail to do that.

Leo: Hallelujah; right.

Steve: Yeah, I know. And it's refreshing to see it, but it always surprises me because I don't remember to do it. They said: "The Commission paper includes proposals to deliver a 'technology roadmap' on encryption issues with expert input, and emphasizes the need to reconcile technology and lawful access concerns" - oh, gee, you think? - "through industry standardization activities. This EU initiative complements the Minister's proposed approach to reforming the law on interception in Ireland and will inform the development of the General Scheme." And that's capital G, capital S, so the General Scheme is something that they're going to inform and develop.

So, okay. I have, of course, much to say about this. But I want to first share the pre-release's fourth point regarding "the inclusion of a new legal basis for the use of covert surveillance software as an alternative means of lawful interception to gain access to electronic devices and networks for the investigation of serious crime and threats to the security of the State."

They write: "The Minister also proposes to provide a legal basis for the use of covert surveillance software as an alternative means for lawful interception to gain access to electronic devices and networks for the investigation of serious crime and threats to the security of the State. This is used legally in other jurisdictions for a variety of purposes when necessary, such as gaining access to some or all of the data on an electronic device or network, covert recording of communications made using a device or disrupting the functioning of a personal or shared IT network being used for unlawful purposes.

"The Minister proposes to take into account a 2024 report from the European Commission for Democracy through Law to the Council of Europe (the Venice Commission) on this subject, which was titled 'Report on a Rule of Law and Human Rights-Compliant Regulation of Spyware.'"

So in other words, conduct that has historically been denied by governments, which were doing it anyway, and which no state agency would admit to using or doing, is now being ratified into law and made explicitly legal. I believe that any objective observer who has witnessed the earlier saber rattling and more recently both the pending and enacted legislation that governments are, you know, seem determined to pursue would have to conclude that we are currently in an environment of slowly eroding privacy protections.

Encryption happened; right? I mean the math happened. and along with everyone else who appreciated knowing that their communications were private, you know, which, you know, it was just kind of like "Okay, thanks, that's nice to have," bad guys started using it, and they soon discovered that it protected them from law enforcement. While encryption was not created by any means to protect criminals, the privacy it affords everyone, you know, the privacy it affords doesn't know or care whether you're doing good or breaking the law if your communications is encrypted.

So when bad guys began hiding behind the same encryption that everyone else was using, because it was there, law enforcement quite reasonably asked providers for the contents of the bad guys' encrypted messages. And they were told that the system had been deliberately designed to provide absolute communications content privacy for all of its users, regardless of their use; and that we, the providers of this technology, were unable to comply with lawful court orders to turn over their users' data. They said they did not have that data, and they had no means of obtaining it.

Now, that stumped the world's governments for a few cycles until someone had the bright idea to simply require the world to work differently. They said: "We all agree that citizens have fundamental rights to privacy, except in cases where that privacy is being abused and is not in the public interest. So we've decided that we will determine when and where people should have privacy; and since we're a nation of laws, we're going to make it legal to do whatever we need to in order to obtain the privacy-violating access to our citizens' communications that we have determined we need to have - always, of course, in support of the greater good. And besides, think of the children."

That same objective observer that I talked about before would see that we're currently in a period of transition. The truth of encryption caught the world's governments off guard. They've all seen the same movies that we have. Those movies - think about it - uniformly depict both hackers and intelligence services "cracking the encryption," like whenever they were asked to, whenever it was really necessary to do so. So everyone knows that "really good encryption" just takes somewhat longer to crack; right? That's what the movies all showed us. The politicians just assumed that was true. Why wouldn't they? They believed that was the way encryption really worked. Right up until they encountered the truth of today's encryption, they really didn't understand that modern encryption is absolutely unbreakable. That's what the industry created. Period.

So what we've seen is that it took them several rounds of stumbling and failed legislation and trying to figure out how to ask for what they wanted to finally figure out that what's actually needed is for them to outlaw any encryption that no one can break. They want the encryption we have in the movies, and they're going to keep writing and rewriting legislation until they get it. So the formal legalization of the use of spyware is just the next step along that path. Now they're saying, "We're going to make our use of spyware legal. That will be lawful if we decide that we need to deploy it in order to obtain access to encrypted communications." Another step down that path.

So we're not yet where we're going to end up. But again, our objective observer of the last several years would have to conclude that the world's governments, their law enforcement and intelligence agencies, will not be satisfied until it's possible to obtain access to the communications probably of anyone they desire.

Leo: It strikes me this is a pretty savvy move on the part of the Irish government because I think what they're recognizing is, well, we can't demand cleartext from Signal, WhatsApp, and all these companies.

Steve: Right.

Leo: So the next step is, and we've talked about this before, to go pre-encryption, to go where the messages are in plaintext, that is, on your device.

Steve: Yup.

Leo: Pre-encryption. And to do that they need the spyware. So I think this is the next stage, and this is saying, all right, I get it, you know, Signal is going to withdraw from Ireland if we make it illegal to have strong encryption. So, oh, I've got it, we'll just get on everybody's phone. The next step after this is what Russia and China do, which is mandate that you put a special app on the phone so that we can see everything that's going on.

Steve: Roskomnadzor.

Leo: Yeah. But that's, now, the interesting thing is they may have to go to that point because I think they may be - here's where they're technically less literate. They may overestimate the ability of spyware to do this; right? But these kinds of exploits are not easy to get.

Steve: No.

Leo: They're generally one-time use because, you know, Apple will patch it the minute they figure it out.

Steve: Exactly. As soon as anyone finds it they're able to say, whoops; you know?

Leo: So they may have a - this may be where they're, you know, before they thought, oh, we can break encryption. Now maybe they're starting to realize we can't. Oh. But spyware. But maybe they don't really understand. It's not as trivial as you might think. I mean, I guess the NSA had its tools. That's what we learned from Edward Snowden.

Steve: And you're right. It may be that where we end up, where they, for example the EU ends up is requiring an app on everyone's phone.

Leo: I think it's the only - it's the ultimate; right?

Steve: Yup.

Leo: Everybody has to run this app. And then they can see everything, and it's all pre-encryption. So Signal, you can still use Signal. Well...

Steve: Yes. It's bad PIE. Pre-Internet Encryption was a good thing once.

Leo: Right. It's Pre-Internet Decryption. It's PID.

Steve: Yeah, yeah.

Leo: But the other good side of this is, as you say, the math happened. And it's all - it's easy. It's well known how to do encryption now.

Steve: Yes.

Leo: So it's going to be pretty...

Steve: So the counterargument is, when it's illegal, only the criminals will use it.

Leo: Right. Or people who are motivated and/or smart enough to figure out how to do it without...

Steve: Well, again, I mean, they're going to outlaw their inability to spy.

Leo: Right. They're going to try.

Steve: In which case you will be a criminal even if you're just encrypting to talk to your mom. If they want to see what you said to Mom, and you're unwilling to give them the keys, then you're guilty of that.

Leo: You know, I said this in an interview 25, maybe, no, 30 years ago, that ultimately hackers might be the freedom fighters of the 21st Century. The people who understand how to get around these things may actually be the people who are fighting for our freedom.

Steve: Yeah. Neo.

Leo: Neo. Yeah, right, Neo. This was before "The Matrix."

Steve: Let's take a break.

Leo: All right. I'll let - do you want to refresh? Do you want to hydrate? Okay. He's nodding, folks. You can't hear it, but his head is vigorously bobbing up and down, and he has a gigantic mug of joe in his hand. Back to you, Steve.

Steve: So the day after Ireland proudly enumerated the various features of its newly passed expansive legislation, EDRI, the European Digital Rights organization, perhaps in response to Ireland's announcement, posted under the headline "EDRI launches new resource to document abuses and support a full ban on spyware in Europe." And, you know, okay, good luck. It seems that the European Union has their own equivalent of the EFF, and it's EDRI. Their posted piece begins by stating "The Context: Europe's spyware crisis remains unresolved."

And they write: "Spyware remains one of the most serious threats to fundamental rights, democracy, and civic space in Europe." And of course, Leo, as you just pointed out, spyware is just where Europe wants to go because they want the access that they can't get. EDRi said: "Over the past years, repeated investigations have shown that at least 14 EU Member States have deployed spyware against journalists, human rights defenders, lawyers, activists, political opponents, and others." Notice we're not saying criminals. We're saying people we don't like for one reason or another. We're going to just spy on them. So who imagines that that won't accelerate hugely if spyware is made legal? Anyway, that's me.

EDRi said: "These cases have revealed the reality of an opaque, dangerous market that thrives on exploiting vulnerabilities and endangering us, and the states' reluctance to provide any accountability or justice for victims." Right, so they're going to legalize what they've been doing.

"Despite the findings of the European Parliament's PEGA Inquiry Committee in 2023, and the push from human rights organizations, the European Commission has so far refused to propose binding legislation to prohibit spyware. Not only that, it has done nothing. Right now, no EU-wide red lines exist against the use of spyware." Well, right. Fourteen states have done it, and they want to be able to keep doing it.

So they wrote: "This means that victims lack effective remedies, authorities face no scrutiny, and commercial spyware vendors continue to operate with near-total impunity, enriching themselves by violating human rights, and even benefiting from European public funding." Because after all, this is taxpayer dollars, and this spyware's not cheap.

"At the same time," they said, "this political inaction is increasingly being challenged. Investigative journalists, researchers, and civil society organizations have continued to expose spyware's human impacts, and the opaque markets behind its development and deployment. A broad coalition of civil society and journalism organizations has openly called on EU institutions to end their inaction and to adopt a full ban on commercial spyware. Adding to this push, EDRi has also adopted a comprehensive position paper calling for a full ban on spyware in the European Union as the only possible path forward from a human rights perspective."

So basically the battle is escalating, and it's being made more visible and more public. We've got EU states wanting to legalize their use of spyware, and the human rights privacy protecting organizations saying let's make it very clear that this is not legal.

They said: "Our collective refusal to accept the normalization of the use of spyware is also visible inside the European Parliament. On the 21st of January this year, in Strasbourg, an informal Interest Group against spyware was launched, bringing together MEPs from across political groups with the aim of maintaining scrutiny and challenging the Commission's inaction. While this does not replace legislative action, it signals that political pressure is growing, instead of fading." Right. Like I said, it's becoming more and more public. So we'll see what happens.

The Spyware Document Pool that this posting introduces is a really terrific piece of work. I'm only going to share a tiny piece of it. But I've dropped a link to the entire pool into the show notes. The end of the URL is spyware-document-pool, and it's at the top of page 6 in the show notes.

The piece I wanted to share from it addressed the nature and the size of the commercial spyware market. They wrote: "The commercial spyware market has grown rapidly over the past decade. This market is now worth billions of euros, driven by the sale of these tools to governments, law enforcement agencies, and sometimes private actors. Its growth is fueled by an ecosystem that combines technological sophistication with near-

total opacity, allowing companies to operate across borders and evading accountability. This makes spyware a highly profitable yet extremely dangerous sector, where abuses remain hidden until uncovered by researchers or investigative journalists. The global spyware industry is estimated to be worth on the order of 12 billion euros per year."

Leo: It's illicit, though; right? I mean, that's...

Steve: Absolutely it is not legal anywhere; right.

Leo: That's amazing.

Steve: 12 billion euros companies are paying. You know, like Maduro in Venezuela. You know, he would be a typical customer because he's got lots of money, and he would like to spy on anybody who opposes him publicly.

Leo: Well, and now they're going to get the Irish government as a customer, so that's good.

Steve: Right.

Leo: Geez.

Steve: More than 80 governments have contracted for commercial spyware, according to the UK's cybersecurity agency.

Leo: Well, that's like half. That's like everybody.

Steve: Yeah. In 2023, there were at least 49 distinct vendors, along with dozens of subsidiaries, partners, suppliers, holding companies, and hundreds of investors across the supply chain. 56 of the 74 governments identified by the Carnegie Endowment procured commercial spyware from firms either based or connected to Israel. The Israeli firm Paragon was acquired in 2024 by an investment firm in a deal worth up to 900 million euros. And this is the market that Ireland, as we have been saying, has just taken out of the shadows and made legal for their own use, for what they're calling "lawful interception."

Leo: Wow.

Steve: The other piece of data that I thought our listeners would find interesting was about the market for the vulnerabilities that enable the creation and deployment of this spyware. They write: "The buying and selling of zero-day vulnerabilities is closely linked to the spyware market, as these flaws allow spyware to bypass security protections and operate undetected. The vulnerabilities market is dangerous because it magnifies risk. A single zero-day can compromise millions of devices. Once a vulnerability is found, the risk is that anyone can exploit it."

And they're saying, for example, by comparison, if a good guy finds a zero-day, they report it, probably receive a bounty, and it's removed from the ecosystem. It's removed from the device. However, spyware using a zero-day never wants to disclose it. They want to use it as long as they can. So that zero-day remains present until it's somehow discovered, so thus magnifying risk.

"Also, it drives innovation in spyware: Spyware vendors continuously adapt their tools to exploit newly discovered vulnerabilities." Of course, as we know, it also drives Apple to keep revising their chips in this ongoing cat-and-mouse battle against what the spyware's able to do. "It lacks accountability: Vulnerabilities are traded secretly, with minimal regulation, creating an ecosystem with no rules that poses a risk to all of us.

"Concentration multiplies risk: Many people are using only two OS (Android and iOS), and some apps are globally used (WhatsApp, Gmail, and so forth). Once someone breaks into one of these systems, they can have access to hundreds of millions of devices." And Leo, this is the point you often make about our monoculture, you know, the fact that there's basically either Android or iOS. There are not 20 different OSES, each struggling to maintain their own security. So this makes the point that, because we have such a very vertical and narrow selection of platforms, you find a problem, you get access to a huge chunk of the world.

They wrote: "A zero-day vulnerability costs, via brokers, between" - okay, so this is what the payout is for zero-day vulnerabilities today - "\$5 to \$7 million for exploits targeting an iPhone. That is, you find a zero-day for an iPhone today, and through a broker you can obtain between \$5 and \$7 million. Android phones get up to 5 million. Chrome and Safari zero days are between \$3 and \$3.5 million. WhatsApp and iMessage pull 3 million for WhatsApp, 5 million for iMessage."

Leo: But this proves my point. They wouldn't be worth that much if they were so easy to use, and you could use them in a widespread fashion. These are very targeted, very specific attacks.

Steve: Yes. Yes. And the reason they're getting that much money is of course the spyware vendors then turn around and charge that much money per customer for...

Leo: To the nation states, yeah.

Steve: Yes, exactly. Which ultimately the taxpayers finance.

Leo: Yeah. Oh, that's nice.

Steve: Since, you know, governments don't generate their own cash. "In 2024 the Google Threat Analysis Group reported that 20 out of the 25 vulnerabilities found on their products" - this is Google's TIG group, so that's Android and Gmail - "in 2023, 20 out of 25 were used by Spyware vendors to perform their attacks. As of June 2025, more than 21,500 new vulnerabilities had already been published." So we're seeing a rate of 133 new vulnerabilities per day. Not all high-quality zero-days in iOS, obviously, but broad spectrum, 133 vulnerabilities are being found of all types everywhere per day.

They finish, or I'm finishing quoting this piece of it: "Even though at least 14 EU countries are reported to have used commercial spyware, regulation in Europe remains

entirely absent." So Germany is saying we want to do this. Ireland is saying now we can do this. And the European Union is for whatever reason making noises like, oh, this is bad, but they're not actually taking any action.

To say that the future of encryption currently exists in a state of tension and uncertainty I think would be no overstatement. Given the reality of the overwhelming power of the world's governments and the necessity for vendors to abide by their laws, right, I mean, as we know, all Signal can do is say, well, we're leaving. They just can't ignore the laws in the prevailing regions where they want to operate. And much as I wish it were not the case, I do not see the interests of the EFF and the EDRi ultimately winning out here. Governments are never going to be satisfied until and unless they're able to intercept and monitor the communications of specific groups of individuals under the order of their courts, at a minimum. That's clearly the path that we're on.

And as for the legal use of absolute encryption? I would say enjoy it while it lasts. Eventually, only criminals will be able to use unbreakable encryption. Its use will have been criminalized so that those who do use it, as I said earlier, will be guilty of at least that. And I think that's where we're headed, Leo. I mean, governments do not - they're just going to object. And it's unfortunate, too, because, you know, while pre-Internet, which law enforcement had to use more analog means, you know, wiretaps and physical searches, everything wasn't binary, either like yes, you have encryption, or you don't. I mean, in the analog world, there's hiding stuff in a mattress. I mean, you know, it was a different world.

Now, it's either it is absolute, I mean, it would almost be better if encryption actually worked the way it did in the movies, but was also very, very, very hard to break; where if you really, really, really, really needed something, you could get it. Unfortunately, what's going to happen is governments are going to legislate themselves the ability to flip a switch and have it all. They're going to say, you know, a phone operating within the European Union must have our software on it. And, oh, it'll have some benefits. It'll be you can use it to take the train and fly and, you know, it'll be stand-in for you and be a digital ID and other things. And it'll also be there, able probably to capture what they want to, when they want to.

Leo: It's, I mean, you could absolutely have a program on a phone that would see all plaintext, you know, everything that was typed in or dictated in before it went into an encrypted...

Steve: Yup.

Leo: That wouldn't be hard to do. You'd have to violate maybe some of Apple's rules. But if you're the government you say, oh, Apple, you don't have to approve this app. We're just going to put it on every iPhone. And it would see everything.

Steve: Yeah. Any macro program that we're used to is able to watch what you do, capture those actions, and then store them. Well, it can also be capturing the keyboard.

Leo: This argues very strongly for an open source operating system. I wish I had a phone that I could really use with an open source operating system. And now with vibe coding I could probably, before this show's over, seriously, code up a, you know, I'd say use NACL or some well-known crypto library that's reliable.

Steve: Yup.

Leo: And I would like you to write me an encryption and decryption program. And I'm going to send my friend Steve the decryption program. And, you know, I think that would be - so it's going to be very difficult to control this. This is like the print your own gun thing. I mean...

Steve: Well, but, yes, it is difficult to control. But that encryption/decryption program that you just mentioned hypothetically, it uses OS APIs.

Leo: Right.

Steve: So, I mean, it doesn't actually - there's no access to the XY coordinates that the user's touching on the screen.

Leo: Right.

Steve: That service is provided by the OS. So that can always be tapped at that level.

Leo: Yeah, I mean, you could capture scan codes from a keyboard, but there's nothing to keep the OS from seeing those, as well.

Steve: Yeah. You need to send me the Leo phone.

Leo: Right.

Steve: And Leo phone is open source.

Leo: And we'd have open source hardware and open source software, and make sure no government intrusion on either.

Steve: Yeah.

Leo: Well, you know that there are people who will be strongly enough incented to do that. And that ironically is the people the government wants to catch. The normal people who aren't doing that, we're sitting ducks.

Steve: Yeah. Which brings us to Microsoft and BitLocker.

Leo: Oh, yeah. Yeah.

Steve: After this next break.

Leo: Okay. And we'll talk about this. This was a news story this week which we talked about on TWiT. And Alex Stamos, who is a very well-respected security guru, did have his thoughts. I want to hear what you have to say about it, and I'll give you Alex's thoughts, as well.

Steve: Perfect.

Leo: Coming up on Security Now!. All right. Let's talk about this BitLocker thing.

Steve: Okay. So on the heels of Microsoft's news and EDRI's pushback comes Microsoft's admission that they provided BitLocker keys to the FBI when asked. The headline of Thomas Brewster's piece in Forbes which set off this firestorm of discussion and controversy was "Microsoft Gave FBI Keys To Unlock Encrypted Data, Exposing Major Privacy Flaw," with the tag line "The tech giant said it receives around 20 requests for BitLocker keys a year and will provide them to governments in response to valid court orders. But companies like Apple and Meta set up their systems so such a privacy violation is not possible."

Okay. So here's what we learn from Forbes' reporting. Thomas wrote: "Early last year, the FBI served Microsoft with a search warrant, asking it to provide recovery keys to unlock encrypted data stored on three laptops. Federal investigators in Guam believed the devices held evidence that would help prove individuals handling the island's Covid unemployment assistance program were part of a plot to steal funds. The data was protected with BitLocker, the software that's automatically enabled on many modern Windows PCs to safeguard all the data on the computer's hard drive.

"BitLocker scrambles the data so that only those with a key can decode it. It's possible for users to store those keys on a device they own, but Microsoft also recommends BitLocker users store their keys on its servers for convenience. While that means someone can access their data if they forget their password, or if repeated failed attempts to login lock the device, it also makes them vulnerable to law enforcement subpoenas and warrants. In the Guam case, Microsoft handed over the encryption keys to investigators.

"Microsoft confirmed to Forbes that it does provide BitLocker recovery keys if it receives a valid legal order. Microsoft spokesperson Charles Chamberlayne said: 'While key recovery offers convenience, it also carries a risk of unwanted access, so Microsoft believes customers are in the best position to decide how to manage their keys.' He said the company receives around 20 requests for BitLocker keys per year; and in many cases, the user has not stored their key in the cloud, making it impossible for Microsoft to assist.

"The Guam case is the first known instance where Microsoft has provided an encryption key to law enforcement. Back in 2013, a Microsoft engineer claimed he had been approached by government officials to install backdoors in BitLocker, but had turned the requests down. Senator Ron Wyden said in a statement to Forbes: 'It is simply irresponsible for tech companies to ship products in a way that allows them to secretly turn over users' encryption keys. Allowing ICE or other Trump goons to secretly obtain a user's encryption keys is giving them access to the entirety of a person's digital life, and risks the personal safety and security of users and their families.' Ron Wyden, of course, a Democrat.

"Law enforcement regularly asks tech giants to provide encryption keys, implement backdoor access, or weaken their security in other ways. But other companies have refused. Apple in particular has repeatedly been asked for access to encrypted data in its cloud or on its devices. In a highly publicized showdown with the government in 2016, Apple fought an FBI order to help open phones belonging to terrorists who shot and killed 14 in San Bernardino, California. Ultimately, the FBI found a contractor to hack into the iPhones.

"Privacy and encryption experts told Forbes the onus should be on Microsoft to provide stronger protection for consumers' personal devices and data. Apple, with its comparable FileVault and Passwords systems, and Meta's WhatsApp messaging app also allow users to backup data on their apps and store a key in the cloud. However, both also allow the user to put the key in an encrypted file in the cloud, making law enforcement requests for it useless. Neither Apple nor Meta are reported to have turned over encryption keys of any kind in the past.

"Matthew Green, cryptography expert and associate professor at the Johns Hopkins University Information Security Institute said: 'This is private data on a private computer, and they made the architectural choice to hold and retain access to that data. They absolutely should be treating it like something that belongs to the user. If Apple can do it, if Google can do it, then Microsoft can do it. Microsoft is the only company that's not doing this,' he added. 'It's a little weird. The lesson here is that if you [meaning Microsoft] have access to [its users'] keys, eventually law enforcement is going to come for them.'

"Jennifer Granick, the ACLU's surveillance and cybersecurity counsel, raised concerns about the breadth of information the FBI could obtain if agents were to gain access to data protected by BitLocker." And that's really a good point, too. It's like, you know, they're not getting selective access to just what they want. They've got your drive. She said: "The keys give the government access to information well beyond the time frame of most crimes, everything on the hard drive. Then we have to trust that the agents only look for information relevant to the authorized investigation, and do not take advantage of the windfall to rummage around.

"In the Guam case, the court docket shows the warrant was successfully executed. The lawyer for defendant Charissa Tenorio, who pleaded not guilty, said the information provided to her by the case's prosecutors included information from her client's computer, and that it included references to BitLocker keys that Microsoft had provided the FBI. The case is ongoing.

"Both Matthew Green and Jennifer Granick said Microsoft could have users install a key on a piece of hardware like a thumb drive, which would act as a backup or recovery key. Microsoft does allow for that option, but it's not the default setting for BitLocker on Windows PCs.

"Without the encryption keys from Microsoft, the FBI would've struggled to get any useful data from the computers. BitLocker's encryption algorithms have proven impenetrable to prior law enforcement attempts to break in, according to a Forbes review of historical cases. In early 2025, a forensic expert with ICE's Homeland Security Investigations unit wrote in a court document that his agency did 'not possess the forensic tools required to break into devices encrypted with Microsoft BitLocker, or any other style of encryption.' In one previous case, federal investigators obtained keys by discovering that a suspect had stored them on unencrypted drives.

"Now that the FBI and other agencies know Microsoft will comply with warrants similar to the Guam case, they'll likely make more demands for encryption keys, Green said. "My

experience is, once the U.S. government gets used to having a capability, it's very hard to get rid of it."

Okay. So the first takeaway from this is obvious - and it doesn't involve any sort of moral or ethical judgment either way. It's just the facts. Because encryption is absolute and unforgiving, it can be super useful to have a backup plan of some kind; right? Someone who will never forget. Someone to hold onto one's emergency encryption backup keys. There's no doubt about that. Only if you are willing to take sober and full responsibility for never forgetting how to log in would it make sense to have no backup whatsoever, anywhere. That said, one option is to allow Microsoft to be the entity to hold onto your keys in the event of an emergency. They're certainly the default easy choice.

The only downside to that - and again, without any judgment here - is that they will also turn your keys over to law enforcement after a judge approves their request. And that may not be a bad thing if you're certain that this would never become an issue for you. But if that's a concern, it's a good thing that you're now aware that Microsoft cannot be a trusted guardian of your privacy. They will capitulate, and now all global law enforcement and intelligence services know that. So it might be better to entrust those secrets to a close friend whom law enforcement would never think to ask.

But as I said, that's the first takeaway. There's another, and it's much more subtle. But I very much want to point it out to our listeners. This Forbes article reminded me of that previous instance, 13 years ago, back in 2013, when a Microsoft engineer claimed he'd been approached by government officials to install backdoors in BitLocker. My recollection was that it was more than a claim, and that it was also more than once. For one thing, there were multiple people involved. So it wasn't just hearsay from one guy. And so the FBI asked. I don't have a problem with them asking. As the saying goes: "Well, you can ask."

Okay. So to set this up for our listeners, I want to share the first portion of Mashable's coverage of this incident from 2013. Mashable's coverage of the story was introduced with the leading question headline, "Did the FBI Lean on Microsoft for Access to Its Encryption Software?"

They wrote: "The NSA is not the only government agency asking tech companies for help in cracking technology to access user data. Sources say the FBI has a history of requesting digital backdoors, which are generally understood as a hidden vulnerability in a program that would, in theory, let the agency peek into suspects' computers and communications. In 2005, when Microsoft was about to launch BitLocker, its Windows software to encrypt and lock hard drives, the company approached the NSA, its British counterpart the GCHQ, and the FBI, among other government and law enforcement agencies" - that is to say Microsoft approached them - "saying we're about to add encryption to Windows." They wrote: "Microsoft's goal was twofold: get feedback from the agencies, and sell BitLocker to them.

"However, the FBI," writes Mashable, "concerned about its ability to fight crime - specifically, child pornography - apparently repeatedly asked Microsoft to put a backdoor into the software." And they tell their less technical audience: "A backdoor - or trapdoor - is a secret vulnerability that can be exploited to break or circumvent supposedly secure systems. For its part, the FBI categorically denies asking for such access, telling Mashable that the Bureau does not ask for backdoors, and that it only serves companies lawful court orders when it needs to access users' data. And, legally, it would still need a warrant, even if a backdoor did exist.

"Peter Biddle, the head of the engineering team working on BitLocker at the time, revealed to Mashable the exchanges he had with various government agencies. Biddle told Mashable: 'I was asked multiple times,' confirming that a government agency had

inquired about backdoors, though he couldn't remember which one. He said: 'And at least once the question was more like, "If we were to officially ask you, what would you say?"'

"According to two former Microsoft engineers, FBI officials complained that BitLocker would make their jobs harder. An FBI agent reportedly said: 'It's going to be really, really hard for us to do our jobs if every single person could have this technology. How do we break it?'

"The story of how the FBI reportedly asked Microsoft to backdoor BitLocker to avoid 'going dark' - the FBI's term for a potential scenario where encryption makes it impossible to intercept criminals' communications or break into a suspect's computer - provides a snapshot into how U.S. government agencies try to persuade tech companies to weaken their security products, or even poke a hidden hole to make them wiretap-friendly.

"Last week" - and this was written back in 2013, so 13 years ago - "The New York Times, ProPublica, and The Guardian," Mashable writes, "revealed that one of the ways the NSA circumvents Internet cryptography is to ask companies to put backdoors into their products. The FBI is reportedly doing the same in the name of fighting crime, and its persuasion techniques appear to be very similar. According to reports, both the NSA and the FBI are subtle in their requests, which are never formal, never written, but are usually uttered during casual conversations, almost jokingly."

Leo: It's called "plausible deniability." Right?

Steve: Exactly. "Nico Sell, the founder of the privacy-enhancing app Wickr, was approached by an FBI agent after speaking at the RSA security conference at the end of February" - again, 13 years ago - "as first reported by CNET. According to Nico, the agent asked: 'So, are you going to give us a backdoor?' She declined, and after pressing the agent, asked him to explain if he had a written request and to reveal his boss, the agent backed down. Cryptography and security expert Bruce Schneier said he's heard of these same types of tactics from others the government has approached seeking technological backdoors.

"Bruce told Mashable: 'It's never an explicit ask. It's an informal, oblique mention, joking conversation, where you're felt out as to whether you might be amenable to it. If you're amenable, then the conversation continues. If you're not, well, it's like it never happened."

"Despite the requests being informal, Schneier and other surveillance experts are concerned. 'A request is a request,' and despite not being illegal, Bruce said, 'it's coercive.'

"In the case of Microsoft, according to the engineers, the requests came in the course of multiple meetings with the FBI. These kinds of meetings were standard at Microsoft, according to both Biddle and another former Microsoft engineer who worked on the BitLocker team, who wanted to remain anonymous due to the sensitivity of the matter.

"Biddle said: 'I had more meetings with more agencies than I can remember or count.' He said the meetings were so frequent, and with so many different agencies, he doesn't specifically remember if it was the FBI that asked for a backdoor. But the anonymous Microsoft engineer we [meaning Mashable] spoke with, confirmed that it was, in fact, the FBI.

"During a meeting, according to Biddle and the Microsoft engineer, who were both present at the meeting, an agent complained about BitLocker and expressed his frustration, saying 'You guys are giving us the shaft.' Though Biddle insisted he didn't remember which agency he spoke with, he said he did recall this particular exchange. And Biddle wasn't intimidated. He replied: 'No, we're not giving you the shaft. We're merely commoditizing the shaft.'

"Biddle, a believer in what he refers to as 'neutral technology,' never agreed to put a backdoor in BitLocker. And other Microsoft engineers, when rumors spread that there was one, later denied that was ever a possibility. Niels Ferguson, Microsoft's cryptographer and principal software development engineer, wrote: 'The suggestion is that we are working with governments to create a backdoor so that they can always access BitLocker-encrypted data. That will happen over my dead body.'"

Leo: Wow.

Steve: "For Biddle, this" - I mean, these guys were serious. And if you take a look, Biddle has a Wikipedia entry, and you get a sense for him. You know, those were the good old days of Microsoft. Mashable writes: "For Biddle, this was proof of a fundamental paradox facing government agencies and security software. How do you get secure software you can rely on, while also retaining the ability to break into it if people use it to commit or cover up their crimes? Biddle said: 'I realized that we were in this really interesting spot, sort of stuck in the middle between wanting to do a much better job at protecting our users' information, and at the same time realizing that this was starting to make government employees unhappy.'"

"Despite Microsoft's refusals to backdoor its product, the engineers kept working with the FBI to teach them about BitLocker and how it was possible to retrieve data in case an agent needed to get into an encrypted hard drive. At one point, the BitLocker team suggested the agency target the backup keys that the software creates. In some instances, BitLocker prompts users to print out a piece of paper with the key needed to unlock the hard drive, to prevent loss of data if the user forgets his or her key. The anonymous Microsoft engineer said: 'As soon as we said that, the mood in the room changed dramatically. They got really excited.'"

"In that instance, law enforcement agents wouldn't need a backdoor at all. As the engineer suggested, all they would need was a warrant to access a suspect's documents and retrieve the document that would unlock his or her hard drive."

Okay. And this finally brings me to the point I wanted to make. Mashable quotes Christopher Soghoian, writing: "For Christopher Soghoian, a privacy and surveillance expert at the ACLU, whether or not BitLocker has a backdoor or not isn't even that relevant" - again, 13 years ago - "since it's a feature that very few Windows users employ or even have access to. It's not included in most Windows versions, and it's not a default setting, something that Soghoian said 'is not an accident.'"

"He told Mashable: 'The impact is minimal because so few people use BitLocker, but it does speak to a friendly relationship between the companies and the government.' He said: 'If you want to keep your data out of the U.S. government's hands, Microsoft is not your friend. Microsoft is unwilling to really make the government go dark. They're never really willing to protect their customers from the government. They are willing to take some steps, but they don't want to go too far.'"

Leo: This is from an era when we were still using TrueCrypt.

Steve: Yes.

Leo: And that was the choice for people who really cared about privacy.

Steve: Right. So what I wanted to share about that last bit was I think that's wrong. Okay. So first of all, this is a reminder about the way the world has changed during the intervening 13 years. At the time Christopher Soghoian was quoted, he correctly noted that BitLocker was a non-issue since it was so infrequently used; right? The FBI probably wouldn't actually encounter it in the field. I doubt he would feel the same way about BitLocker today. It will not be enabled on machines that have been upgraded to Windows 11, if earlier Windows was not using it. But most modern PCs that ship with Windows 11 preinstalled, even the Home Edition with its simpler Device Encryption, which is a, you know, a BitLocker without as much UI and options, will have their hard drives encrypted out of the box if they're using a Microsoft account.

To me, this seems entirely pro-consumer. Microsoft doesn't have to push BitLocker encryption. It certainly causes some pain and annoyance for both them and their Windows users. But it's extremely good for the privacy of their users that someone cannot remove their machine's drive and mount it on another machine to dump its entire contents. Those days are over.

Might this mean that the FBI needs to obtain a court order to compel Microsoft to disclose the encryption keys of someone whom they have convinced a judge may have evidence crucial to a crime which they're working to solve? Yes, that might be necessary. But all of that is only necessary because Microsoft is pushing everyone to encrypt their drives in the first place, and there's no way any law enforcement agency anywhere is happy about that. If Microsoft were not defaulting to using BitLocker, things would still be the way they were 13 years ago when Christopher Soghoian said, "Who cares anyway? No one uses BitLocker!" Today, most new systems do. And most Windows users obtain the huge benefit of having their drives' data much more securely protected from non-casual, non-government attack than if it were not encrypted.

I don't disagree that Microsoft might be able to do more, and that they may be shortchanging their users' privacy when push comes to shove. If they can provide unlocking keys to their users in an emergency - and that's the point, right, of their escrowing - then they can also provide them to law enforcement when under order to do so by a court. On balance, I would venture that many, many, many more Windows users' data have been saved by this policy than have been compromised by law enforcement subpoena. I'm sure that Microsoft would always require a court order before disclosing. That's a given. It's not as if anyone can just ask for someone else's decryption keys and get them.

So the data does have the same protection as does our other personal property and possessions. The protection is not absolute, no. And, yes, if users were capable of taking full responsibility for the decryption of their data, that is, for backing up their keys, then it could be absolute. But at least in the United States, the protection is in line with what U.S. citizens enjoy in the other areas of our lives.

So anyone who objects to turning their keys over to Microsoft has now been forewarned that their keys, if it's a concern, may be disclosed to law enforcement upon legal demand. If that's a concern, Windows Pro, and Enterprise, and Education edition allow users to disable Microsoft's default key escrowing by setting two policies. There are two policies in the registry. Do NOT allow BitLocker recovery information to be stored in Azure AD, and do NOT allow BitLocker recovery information to be stored in Microsoft

account. After doing that, their BitLocker recovery keys can be rotated so that Microsoft never obtains the updated keys.

BitLocker was designed correctly the way all modern crypto is, so that there is like a full volume master encryption key which never leaves the device. Then there is another key that encrypts that key. And it's that secondary key which Microsoft gets a copy of. It's also written into the TPM protected by a PIN. And it's also - it's the thing that you're able to back up to a USB. It's the master key encryption key. So it is possible with two simple commands in Windows to rotate that key, basically to discard, while BitLocker is unlocked, so that the volume, the full volume master key is decrypted to rotate the key that encrypts it. After you've disabled sharing this with Microsoft, and if Microsoft has a key, it's no longer of any value.

Remember, though, there's no one to come crying to if you're unable to log into your computer, or there's any sort of problem. So I would absolutely print this on paper. You know, a USB drive, a USB thumb drive is not high-fidelity storage. I wouldn't trust anything that I care about to a USB drive. Print it on paper because it's too important not to. But my feeling is, again, Microsoft doesn't have to be encrypting everyone's drive. Right? And if everyone's drive is not encrypted by default, most would not be, and the FBI would have no problem. The fact that they have chosen to switch to default encryption on, to me that's 100% in the service of their customers. That's a good thing.

And for everybody's sanity, because encryption is absolute, using an online account, which we all know they don't make easy not to use these days, if you can even find a way around it, they're backing up those keys. And again, they're not doing it to be a friend to the FBI, they're doing it because people are going to, and have, forgotten how to log onto their computer. And if you can't do that, you can't access your hard drive ever. So again, I think it's exactly the right set of tradeoffs, Leo. It's everybody's drive is encrypted. There is a Get Out of Jail Free card stored up in Redmond's servers. And you're able to turn that off if you're knowledgeable about how to do so and wish to do so.

Leo: Yeah.

Steve: So what did Alex think?

Leo: I think he essentially agreed with you that it wasn't a hair on fire. It's very good for people to understand that this can happen so that you can make a choice, depending on your tolerance of risk and your threat model.

Steve: And some people may just not want Microsoft to have that ability. I get it. Actually, I wouldn't. Because, I mean, I don't want to have an online account. I don't want Microsoft in my business at all.

Leo: Yeah, there's a lot of reasons not to use an MSA account to log into Windows. It's a shame Microsoft makes that harder and harder and harder. I think that's where maybe Microsoft is a little bit at fault. But you're right. I don't think they're doing it to make it easy for law enforcement to get the data. They're doing it because people lose their keys, and they just want to protect them.

Steve: Yes.

Leo: He pointed out, though, that Apple has found a way to do all of this without having access to the keys in a way that they can give this to law enforcement. Apple, by default, encrypts the hard drives on your Macintosh with FileVault. They do have a way of saying I forgot. But they're using some sort of key escrow system so that they don't actually have access to the key. And as you pointed out, Google also does this. In fact, all phones do this without a backdoor. Remember, the FBI was trying to get Apple to give up the keys in the San Bernardino case, and Apple says, yeah, no.

Steve: Yeah.

Leo: And that hurt, probably hurt their reputation with some people considerably, and definitely buffed it up with some people like me. So I think it's good that we know this. It's good that there are alternatives.

Steve: Yup.

Leo: It is interesting Microsoft doesn't do what Apple does. They could. They could take that extra key escrow step and make it possible to, you know, do it all.

Steve: I'll have to look into that because I don't understand...

Leo: Yeah, I don't either.

Steve: ...what it is that they're doing. Maybe it's because you have access to the physical hardware. But, I mean, if the user doesn't have to remember anything?

Leo: Well, no. The TPM stores it. I think that when you log in, I know when you log in it unlocks it. So it's not, you know, my Linux box, where I use LUKS, I have to unencrypt the drive before I can log in. I mean, that's a two-step process. Apple's not like that. You log in. Then there is a long process, fairly long process of unencrypting the drive, and then you're in. And I'm not sure how...

Steve: So if it's that your device contains the key, and they're able to get it from the device, then it is device-bound.

Leo: Yeah, I think that's what it is, like TPM.

Steve: Okay. And that makes sense. But then what happens if the user loses their device? They have a backup, and that's when they want to use the backup to restore it onto a different device. But that new device won't have that secret. So again, I've not looked at this for so long, and things change. But it would be interesting to know...

Leo: It generates a recovery key, which you could print out.

Steve: Ah.

Leo: And that you can use.

Steve: Okay. In that case...

Leo: And Apple doesn't have access to that.

Steve: In that case it's exactly like what we would do with BitLocker, except that Microsoft defaults to also having a copy of that recovery key.

Leo: Right.

Steve: Apple does not default to having a copy of the recovery key.

Leo: Yeah. You can allow my iCloud account to unlock my disk, which is the BitLocker solution. And Apple's explicit, by the way, when you set this up about how to do this. Unlike Microsoft.

Steve: It's why I've chosen them to be the backbone for my stuff is I trust them more than anybody else.

Leo: I mean, look, we automatically, on mobile devices, it's all encrypted. Automatically. Yeah, you know, we talked about this the other day when I was setting up this Linux laptop. I just think it's better to encrypt it because that way you don't have to worry about erasing it and the issues of is some of this going to be, you know, accidentally stored on an SSD and all of that stuff. It's just it's gobbledygook without the password.

Steve: Without the master key.

Leo: Yeah. I like that. I think that's the right way to go. I'm comfortable with that. And yeah, I have to enter my password twice on my Linux box. Well, I enter it once, and I use a fingerprint the second time.

Steve: Yeah.

Leo: I don't find that to be too onerous.

Steve: No. I think biometrics is going to be the way - the way things are going, we're having to authenticate more and more often to say that we're sitting in front of our computer. And so just having a fingerprint reader in a keyboard or a mouse makes a lot of sense.

Leo: It's a great - it's a great solution, yeah.

Steve: So we heard from me, and we heard from Alex Stamos. We're next going to hear from Alex Neihaus, after this break.

Leo: Okay. Our long-time friend, one of the, in fact the very first advertiser...

Steve: Yeah, Astaro.

Leo: Astaro. By the way, Chris Soghoian, for those who are wondering, is Sal Soghoian's brother. Sal, of course, very well-known Apple guy for a long time. And his brother's a very well-known security guy.

Steve: Yeah.

Leo: So that there is - that is the same Soghoian. That's the Soghoian family. Now on we go with more Security Now!. Steve?

Steve: Friend Alex shares I think some tremendous business-centric perspective on what the application of AI will mean to the enterprise and what pitfalls it's more than likely to offer. So he writes: "Gents, Security Now! has spent a lot of time over the last couple of months on AI and how its first, most 'natural' application is software development. After a recent experience packaging up a hobby script as a public open source PowerShell module, I could not agree more that the development toolset is rapidly changing. But - there's always a but - I worry about 'mechanically' produced code, particularly in enterprise systems that deal with financial and personal information at scale. Think a brokerage or a multi-state healthcare system.

"If we look at the historical waves of management thinking about the development costs of crucial enterprise systems, we see an endless push to reduce those costs. That's inevitably led to declines in quality, reliability, and most of all security. In the early days of enterprise development, engineers worked in-house. I started as a developer at Mass. General Hospital in the 1980s when 'outsourcing' was not yet in the lexicon. Yet MGH developed MUMPS in-house, which today is the core database environment of the largest electronic medical records vendor in the USA.

"Outsourcing became all the cost-cutting rage among enterprises, followed-on quickly by the offshoring of enterprise development. Executives, based on then-current business consulting doctrine, decided that IT wasn't their core business. They thought their businesses just made widgets or sold products or provided a service. IT was orthogonal to their core function.

"History shows what a strategic mistake that thinking was. It led directly to the situation we find ourselves in today: a race to the bottom to procure development resources that cost a fraction of in-house resources. Security Now! regularly documents the results: breaches, botnets, system failures, and worse. Over time, enterprises discovered their IT systems are the business. You can't make a widget, sell it, or service it without an enterprise system. Unfortunately, many businesses continue to dismantle their core capabilities with a massive, mistaken 'shoemaker's children' syndrome. "AI's rapid

development means yet another giant epoch in computing technology is just starting. We're about to live through another turn of the wheel of technological progress.

"Having used AI in a simple vibe coding project, it's clear to me that AI cannot replace developers. But that's how it's being pitched to the same enterprises that previously committed the 'not our core function' mistake. Amazon and Microsoft are both insisting that replacement is the primary benefit. Enterprises now completely beholden to these hyperscalers take their cues from them. I use AWS and Azure cloud products every day in real client situations; I can tell you quality isn't their north star. Anyone who's ever struggled with Microsoft's automated API documentation can tell you it isn't worth the electrons used to display it.

"In other words, we should not repeat the mistaken business assumptions that drove the outsourcing debacle. Instead, we can upscale developers' skills while still retaining the focus on human development. Imagine the benefits if we used AI not to replace those \$25/hour outsourced developers who produce the worst code we've ever seen, but instead train them to use AI to write tests, to check the level of every included NPM or PyPI package against the CVSS database before recompiling or to fuzz their functions. (That last is the hallmark of outsourced code vulnerabilities. It works, but only on the happy path.)

"We're still in the early hype-cycle days of AI. But the hype sometimes becomes at least the partial reality. Thinking about AI only as replacement for developers makes the same mistake we made with outsourcing, only magnified many times.

"You both know how much I love the show, and your tenacity in producing compelling podcasts week after week, decade after decade. Thanks for that. Security Now!'s #1 fan, Alex."

So wanted to share Alex's perspective because I think it is super valuable and exactly correct. It also makes such complete sense. My own perspective tends to get wrapped up in the technology, so the effect AI will be having on internal enterprise development isn't the sort of thing I tend to focus on. So thank you, Alex. I imagine this may give many of our enterprise-centric listeners something to think about and perhaps discuss with their peers and managers. And Leo, you can see his point; right?

Leo: Oh, he's absolutely right, yeah.

Steve: It's absolutely being sold as think of all the people you can fire.

Leo: Right. Well, and we talked about this last week. I mean, and I've been thinking about it since you posed the question. The skills that you have as a coder are not thrown away.

Steve: The maturity, yes.

Leo: When you're doing vibe coding. You very much need similar skills. It's almost as if you're a team leader working with junior coders and instructing them.

Steve: Yes, right.

Leo: The sad thing, I think the real problem we're going to have is that a lot of companies are using AI coding tools to replace the junior programmers. Which means there's no longer a pipeline for people to become, you know, senior programmers because they don't get to do it. So I hope companies will continue to hire entry-level coders to work with these tools. What's interesting is you're going to get a lot more applicants who are very skilled with these tools. That's what kids are doing in college right now in computer science classes.

Steve: Right.

Leo: They're learning how to use these tools. And maybe, let's face it, maybe that's the future of coding. I wouldn't be surprised. It's just another kind of high-level language. It's just higher.

Steve: I do think it's the future. I agree with you completely. I think it's very clear that AI has such a profound ability to code that learning how to get AI to give you the answer that you want is...

Leo: Part of the learning, yeah.

Steve: Yeah.

Leo: But Alex is right. We can't treat it as a panacea. We have to think about the consequences and how we're going to keep that pipeline going and how we're going to go forward, instead of throwing everything out and starting over. Because that's not going to work, either.

Steve: Well, I think we're going to go through a period of pain, Leo, while...

Leo: Oh, yeah. We know that.

Steve: While the C-suite executives realize, uh, whoops, we did throw out the baby.

Leo: Whoops.

Steve: Gavin has a confession to make, another listener of ours. He said: "Hi, Steve." And he says right off: "I have a confession to make. I have knowingly opened up public database access in production systems." He said: "Here's how this came about. A few years ago I became the sole software developer at a small UK ISP, following the departure of several senior team members. The company had a plethora of legacy systems scattered among various cloud service providers. Following COVID-19, sales plummeted, with many customers shutting up shop, and very few businesses investing in connectivity products. We had to start cutting costs or risk going under ourselves.

"One of our biggest costs was managed database instances. My predecessors had spun up individual database servers (mainly MySQL and Postgres) for each of our many

applications across different clouds (AWS, Digital Ocean, et cetera), and multiple different accounts within each. In terms of application isolation, it was a great approach, but it was costing a small fortune.

"My task was to consolidate as many of these databases as possible, which would bring our costs down quickly, amounting to thousands of pounds per month. There were three possible ways of accomplishing this after first migrating all application databases to a central instance. First, move all of the applications from the various cloud accounts into a single account and VPC (Virtual PC) so they could all access the new database instances privately. Or give each of our applications static IPs and set up security rules in front of the new database instances to limit their access. Or open up full public access and make the passwords as strong as possible." Now, remember Gavin is a listener, so he knows what he's saying.

He wrote: "The problem with moving all of our applications is that it would take a very long time, and many of them relied on cloud provider-specific utilities and network configurations for which we would need to find alternatives and rewrite large swaths of legacy code." In other words, there was a lot of lock-in, and actually moving them would have meant, you know, would have been a huge burden.

Or the second question, he says: "The problem with the static IP solution is that they became quite expensive," meaning static IPs, "and some of our platforms (Digital Ocean Apps, for example), at the time didn't offer them at all." So static IPs were out. You couldn't use static IPs and firewall rules.

"So," he writes, "reluctantly, the third option was chosen, and management were happy to take on the additional risk" - right, right up until there's a major breach, they're happy. He said: "Management were happy to take on the additional risk, which I explained to them, especially in light of the immediate expected cost savings."

He says: "And so, for about four years, we were running with our main databases publicly exposed to the Internet. But now, today, after a lot of work, all of our apps are in private subnets and linked VPCs; and, thankfully, our databases are no longer exposed.

"I know that my company was not alone in doing this sort of thing, having spoken with other devs in the industry. So here it is, a real world example of how this can happen and not through negligence, rather through unfortunate resource pressures. Luckily, we were never compromised (to our knowledge)" - good for you, Gavin, for acknowledging that - "and we just about managed to bounce back as a business. And I'm making sure this sort of thing won't happen again. All the best, Gavin, listening since 2018."

So first of all, Gavin, confession is always good for the soul. Second, I have no problem whatsoever with what you needed to do because none of it was done blindly or without thought and a clear understanding and balancing the costs and the potential consequences. So I would judge that to be, while of course not maximally safe, at least entirely responsible. You were not irresponsible. And given the constraints you were operating under, the interim solution you adopted was the best you could achieve. No one should fault you for that.

John David Hickin, his subject was "On ISP's Selling Your DNS Data." He wrote: "Can't you just set up the ISP's modem/router as an edge router," he says, "(turning off WiFi as well) and connect another router or more behind that?" He says: "An old solution of yours repurposed. Cheers, John."

Okay. So I received other similar questions, and he's talking about ISP spying. So I wanted to take a minute to examine the ISP's advantage. What we need to consider is

that our ISPs - mine is Cox Cable - knows exactly who we are by household name, address, and payment information, and they are in the very special and privacy-sensitive position of having direct access to our individual Internet traffic. We've invested endless podcasts examining cookies and fingerprinting and tracking beacons and all manner of privacy breaching and privacy protecting solutions and technologies. And there, among it all, sits our ISPs, through which every bit, byte, kilobyte, megabyte and gigabyte of our traffic flows. No one else on the entire planet enjoys such direct access to exactly what those in our household are doing from moment to moment.

Now, before the era of Let's Encrypt and their great "Encrypt the Internet" TLS revolution, our ISPs were often privy to the detailed content of everything we did. In retrospect it was quite bracing. Today, with everything encrypted, ISPs are unable to see into our connections, but they can still see where we're connecting. And if we are not encrypting our DNS, they can also track every domain name anyone in our household, and any of our home's IoT devices, looks up.

Tracking the remote IP we're connecting to is much less useful today than it was years ago due to the massively widespread use of multi-domain hosting. Cloudflare has a large pool of IP addresses which provides services to their large pool of customer websites. Among those there's a many-to-many relationship. So having an ISP only able to see a customer's traffic destination is far less useful today than it was 20 years ago.

However, there's still a problem, and that's that SNI - the Server Name Indication - that's carried in the TLS Client Hello handshake is only encrypted when both ends support and negotiate TLS v1.3. TLS 1.3 introduced ECH - Encrypted Client Hello - for the express purpose of preventing anyone who might be examining Internet traffic - like an ISP - from picking up the destination domain of any new connection. At this point in time, at the start of 2026, more than half of all Internet traffic is now using TLS v1.3. But less than half, like at least a third, is still not. But yet the privacy leakage that has continued to occur during the TLS handshake is slowly draining away over time and eventually will all get to 1.3.

After destination IP and TLS handshake leakage, DNS is the remaining potential privacy leak. Firefox users are now being automatically protected thanks to an agreement between Mozilla and Cloudflare to use Firefox's built-in DNS over HTTPS with Cloudflare's DNS resolvers by default. So Firefox users, default protection.

But the Chromium browser family by default will upgrade to DoH if and only if the DNS provider the user has manually configured for unencrypted DNS also supports DoH. This is called "Opportunistic DoH." But since most users have not manually reconfigured their DNS and just run with whatever DNS their ISP has provided, that will be unencrypted DNS over UDP. So only people using Firefox today will have their DNS lookups masked from ISP snooping. And I don't know why. But that's the way it is.

One increasingly popular solution is to use or obtain a home router that can perform its own remote DoH lookups and configure it to use one of the major free CDN DNS solutions offered by Cloudflare, Google, OpenDNS, NextDNS or whatever service you choose. After that, all of the internal network's DHCP-configured devices, meaning typically all of your computers and mobile devices and IoT devices, which would all be using DHCP to get their LAN IPs, will be using standard DNS to the router, but then all queries for domain names will be encrypted and handled by the router. ISP sees nothing.

So with everything using TLS now, and TLS moving to v1.3 with Encrypted Client Hello to mask the target domain, and your browser or router using DoH, the only remaining privacy concern is an ISP able to observe the destination of your traffic. I don't see that ever going away. As I noted, thanks to the increasing use of CDNs and cloud hosting, which aggregate many domains among IP addresses, that's far less certain than it once

was. An ISP can't absolutely know where you're going. But for anyone desiring absolute privacy from ISP snooping, the final step would be to use some form of traffic tunneling. So that means TOR or a VPN. Using one of those means that the ISP is able to determine nothing beyond the fact that you're using TOR or a VPN. That they can see. But nothing else.

So circling back around to John's question, it should be clear that as long as an ISP is the carrier of a subscriber's traffic, nothing else the user might do inside their network, like a router within a router, would change the nature of the traffic which emerges from their LAN to pass under the ISP's watchful and perhaps curious traffic logging or monitoring eye, if they're doing that. Don't know one way or the other on any specific issue.

And finally, Troy Shahoumian - hope I said that right, Troy. He said: "Steve, OMG! I just realized how many podcast files I have that probably need rewinding! Can you recommend a program to do this?"

Okay. So Troy, first of all, I feel your pain. And I can only imagine the size of the podcast rewinding backlog you might be facing now. I know that many of our listeners also listen to other podcasts. So your burden might be even larger. But just taking Security Now!, since this is podcast 1,062, if you've been listening from the start, or if you started late, then went back to catch up from the beginning, and if, God help you, you have not previously rewound any of those...

Leo: None of them?

Steve: ...before now, well, whew, it's not going to be pretty. I don't envy the corner that you've painted yourself into. Okay. Now, what you really need is some sort of - and this is what you're asking for; right? - some sort of mass, gang, parallel, podcast rewinder. And I was thinking about this. Once I finish reworking GRC's eCommerce facility, and Lorrie and I get moved to our new place that'll be a project in the spring here, I plan to readdress GRC's ValiDrive freeware. And although I don't have it on my roadmap, I may see whether I might be able to sneak in some sort of mass podcast rewinding facility, sort of as a side feature, so you could copy the podcasts onto a thumb drive or, you know, USB attachable storage, and then I would have ValiDrive just rewind them all for you. So...

Leo: I have already started the vibe coding to help me write a podcast rewinding program. Claude says "I'll be happy to help you build a podcast rewinding program. I need to understand more of what you're looking for. Do you want a command line, a desktop GUI, a web app, a mobile app?"

Steve: Can we get all the above, Leo? Because...

Leo: Well, we could. Let's do it in Python.

Steve: This is why we have AI and data centers is that so we can rewind people's podcasts. It's an unappreciated problem.

Leo: We want basic playback controls, which would include rewind. Variable speed playback, podcast feed management, progress tracking. Yes, let's do it all. Okay.

Steve: We definitely need progress tracking because with 1,062 podcasts to be rewind after you finish listening to this, you're going to have to see how far along you've gotten. It's not clear to me, well, we don't really know yet, do we, how quickly a podcast can be rewind.

Leo: That's a good question. And that's probably why I probably shouldn't have chosen Python. But something - maybe I should have written this in C, something a little faster.

Steve: Oh. You've got to use a compiled language, yeah. You don't want to, you know. Maybe, you know, people did...

Leo: Whoa. I'm sorry, I clicked a button and it erased us both. Here we go.

Steve: I'm sorry.

Leo: People did what, you were saying?

Steve: People did buy like a little standalone PC in order to run SpinRite.

Leo: Oh.

Steve: If it turns out that rewinding podcasts does take some time per podcast, then maybe it would make sense to get a little auxiliary PC so you're just, you know, so you're not locked out of getting any work done while your podcasts are being rewind, especially if you've got a large backlog.

Leo: We need asynchronous podcast rewinding for sure.

Steve: Yeah, definitely parallel multitasking.

Leo: Multitask concurrency, yes.

Steve: Yes.

Leo: Yeah, that means I'm going to have to use a - probably Rust would be good for that.

Steve: Fire up a thousand threads and give each one a podcast.

Leo: Yeah, yeah, yeah. Patrick Delahanty said you wouldn't believe how much time TWiT spends rewinding podcasts because listeners didn't do it themselves. So...

Steve: Really. Remember, it was that sticker, the sticker on Blockbuster said "Be Kind, Rewind."

Leo: Be kind, be kind.

Steve: Be kind, rewind.

Leo: It's for us all. We're doing this for all of us.

Steve: Just don't think of yourself. When you're done watching a podcast, just leave it there, leave it hanging?

Leo: Oh, no. I've made a mistake. I've made a horrible mistake. Claude Code says user declined to answer questions. So it's given up. It's given up. I'll start over.

Steve: We're going to take our final break, Leo.

Leo: Yes.

Steve: And then we are going to look at my take on what this means, that AI has now been found generating malware.

Leo: Yeah. Well, we knew it was just a matter of time.

Steve: But it's worse than we thought.

Leo: Oh. Yeah, because it's probably pretty good. It has access to all the malware ever written before, so it can really refine the concept. That's coming up. You're watching Security Now! with Steve Gibson. We're glad you're here. Keep watching. We do the show every Tuesday, so we'll be back in February with the first show of the month.

Steve: Also known as next week.

Leo: Next week. AKA. That's right, Steve always boils it down to the essentials. AKA next week. We do the show every Tuesday, right after MacBreak Weekly. That's about 1:30 Pacific. I'm sorry, I keep breaking my pledge. I want to do this in 24-hour time from now on. I'm getting rid of the o'clocks, the am's and the pm's. 13:30 Pacific. That's 16:30 East Coast time. That's 21:30 UTC. You can watch us live on YouTube, X, Twitch, Facebook, LinkedIn, and Kick. Of course, in the Club TWiT

Discord, as well. Or download episodes from Steve's site or TWiT.tv/sn. And I'll explain all of that at the end of the show. Meanwhile, let's get back - he's hydrated - to Security Now!.

Steve: Okay. What we've been expecting has happened. And it's every bit as bad as we worried it would be. Last Tuesday, Check Point Research published their analysis of a newly discovered malware which they named "VoidLink." Their research was titled "VoidLink: Evidence That the Era of Advanced AI-Generated Malware Has Begun." What we all knew was coming has arrived. Check Point summarized this news with five key points.

They wrote: "Check Point Research believes a new era of AI-generated malware has begun. VoidLink stands as the first evidently documented case of this era, as a truly advanced malware framework authored almost entirely by artificial intelligence, likely under the direction of a single individual. Second, until now, solid evidence of AI-generated malware has primarily been linked to inexperienced threat actors, as in the case of FunkSec, or to malware that largely mirrored the functionality of existing open-source malware tools. VoidLink is the first evidence-based case that shows how dangerous AI can become in the hands of more capable malware developers.

"Third, operational security (OPSEC) failures by the VoidLink developer exposed development artifacts. These materials provided clear evidence that the malware was produced predominantly through AI-driven development, reaching a first functional implant in under one week. Fourth, this case highlights the dangers of how AI can enable a single actor to plan, build, and iterate complex systems at a pace that previously required coordinated teams, ultimately normalizing high-complexity attacks that previously would only originate from high-resource threat actors.

"And finally, from a methodology perspective, the actor used the model beyond coding, adopting an approach called Spec Driven Development (SDD), first tasking it to generate a structured, multi-team development plan with sprint schedules, specifications, and deliverables. That documentation was then repurposed as the execution blueprint, which the model likely followed to implement, iterate, and test the malware end-to-end.

Okay. So we've been rejoicing over the surprising jump in Claude Code's ability to operate. Claude has made enabling end-to-end creation of applications possible. As they say, "Everybody's doing it!" Unfortunately, we've known that "everyone" would eventually include malware authors. That's now happened, and it's as bad as we worried it would be. I'm not going to examine this particular instance in depth because what's the point? There will be another one tomorrow, and the day after, or an hour from now. This is clearly the beginning of an entirely new problem domain. Nevertheless, Check Point's introduction is worth sharing.

They wrote: "When we first encountered VoidLink, we were struck by its level of maturity, high functionality, efficient architecture, and flexible, dynamic operating model. Employing technologies like eBPF and LKM rootkits and dedicated modules for cloud enumeration and post-exploitation in container environments, this unusual piece of malware seemed to be a larger development effort by an advanced actor. As we continued tracing it and tracking it, we watched it evolve in near real-time, rapidly transforming from what appeared to be a functional development build into a comprehensive, modular framework. Over time, additional components were introduced, command-and-control infrastructure was established, and the project accelerated toward a full-fledged operational platform.

"In parallel, we monitored the actor's supporting infrastructure and identified multiple operational security failures. These missteps exposed substantial portions of VoidLink's

internal materials, including documentation, source code, and project components. The leaks also contained detailed planning artifacts: sprints, design ideas, and timelines for three distinct internal 'teams'" - they had in quotes because it was all AI teams - "spanning more than 30 weeks of planned development. At face value, this level of structure suggested a well-resourced organization investing heavily in engineering and operationalization.

"However, the sprint timeline did not align with our observations. We had directly witnessed the malware's capabilities expanding far faster than the documentation suggested. Deeper investigation revealed clear artifacts indicating that the development plan itself was generated and orchestrated by an AI model, and that it was likely used as the blueprint to build, execute, and test the framework. Because AI-produced documentation is typically thorough, many of these artifacts were timestamped and unusually revealing. They show how, in less than a week, a single individual likely drove VoidLink from concept to a working, evolving reality.

"As this narrative comes into focus, it turns long-discussed concerns about AI-enabled malware from theory into practice. VoidLink, implemented to a notably high engineering standard, demonstrates how rapidly sophisticated offensive capability can be produced, and how dangerous AI becomes when placed in the wrong hands.

"The general approach to developing VoidLink can be described as Spec Driven Development (SDD). In this workflow, a developer begins by specifying what they're building, then creates a plan, breaks that plan into tasks, and only then allows an agent to begin implementing it.

"Artifacts from VoidLink's development environment suggest that the developer followed a similar pattern: first defining the project based on general guidelines and an existing codebase, then having the AI translate those guidelines into an architecture and build a plan across three separate teams, paired with strict coding guidelines and constraints, and only afterward running the agent to execute the implementation.

"VoidLink's development likely began in late November 2025" - and remember we're in the end of January - "when its developer turned to Trae Solo, an AI assistant embedded in Trae, an AI-centric IDE. While we do not have access to the full conversation history, Trae" - again, Trae, if anyone wants to google it - "automatically produces helper files that preserve key portions of the original guidance provided to the model. Those Trae-generated files appear to have been copied alongside the source code into the threat actor's server, and later surfaced due to an exposed open directory. This leakage gave us unusually direct visibility into the project's earliest directives. In this case, Trae generated a Chinese-language instruction document. These directives offer a rare window into VoidLink's early-stage planning and the baseline requirements that set the project in motion."

Okay. So Trae (T-R-A-E) is a creation of ByteDance, the famous Beijing-based creator of TikTok. It's been around since last February, so it's relatively new, and it's been maturing rapidly. What makes Trae appealing is that it's an IDE (Integrated Development Environment) centric solution. Trae's documentation explains: "Trae IDE is your powerful AI-powered code editor from ByteDance, featuring Claude 3.5 and GPT-4 and DeepSeek integration." By the way, that's back in February. It's updated now.

"It's designed to be your coding companion, offering AI-assisted features like code completion, intelligent suggestions, and agent-based programming capabilities. When developing with Trae IDE, you can collaborate with AI to boost your productivity. Trae IDE provides essential IDE functionality including code editing, project management, extension management, version control, and more. It supports seamless migration from VS Code and Cursor by importing your existing configurations.

"During coding, you can engage in real-time conversations with the AI assistant for help, including code explanations, documentation generation, and error repair. The interface is fully optimized for both English and Chinese users. The AI assistant understands your code context and provides intelligent code suggestions in real-time within the editor. Simply describe your requirements to the AI assistant in natural language, and it will generate appropriate code snippets or autonomously write project-level code and cross-file code.

"Tell the assistant what kind of program you want to develop, and it will provide relevant code or automatically create necessary files based on your description. With support for multiple programming languages and a rich plugin ecosystem, Trae IDE helps you build complete projects efficiently."

So I want to give everyone a sense for what's happening in this segment of the world. So here's an independent review posting made last May, three months after Trae's release to the world. The guy wrote: "Meet Trae AI: A Free AI Coding Agent With Model Context Protocol (MCP)." He wrote: "AI code assistants are flooding the market, but most still feel like chatbots taped to an editor. Trae AI takes a different route. It ships an Integrated Development Environment with a built-in agent framework that parses your entire codebase, talks to outside tools through the Model Context Protocol, and, crucially, costs nothing to install. If you're still paying for a \$20 monthly subscription, Trae AI is an AI coding agent that offers local-first setup and a zero-dollar price tag, making it worth a test drive.

"So what is Trae? Trae AI is a free AI coding agent with model context protocol that offers itself as a collaborative partner for software engineers. It's designed to fit into a developer's existing coding environment, not as a replacement, but as an intelligent AI assistant. Trae provides budget relief. The main editor and completion model are free, removing the line-item that has kept many finance and ops leaders from greenlighting AI pair-programming pilots. Agentic workflow: Instead of a single, do-everything helper, Trae lets you spin up specialist agents, one for refactoring, another for writing tests, a third for documentation, with each AI agent getting its own prompt, tools, and guardrails.

"Enterprise-style data rules without enterprise pricing. Code stays on your machine. Any files briefly sent for indexing are wiped after embeddings are created. Regional hosting (U.S., Singapore, Malaysia, et cetera) keeps governance teams calm about residency.

"What does Trae AI bring to the table? Working together. Trae's development environment is built to work with existing developer setups. The goal is to improve how developers and AI can cooperate for better outcomes and faster project completion.

"Direct AI Communication. Developers can talk to Trae using straightforward language and simple instructions, and they can delegate work, facilitating a more interactive relationship between humans and AI.

"Custom AI Assistants. Trae offers a flexible system for setting up specialized AI agents. It comes with a standard agent called 'Builder' for everyday tasks. Past that, developers can create their own group of AI helpers, each with specific tools, skills, and ways of working, so the AI can be adjusted to fit precise project requirements.

"Connecting to Other Tools. Trae can link up with different external applications. Currently, it uses a system known as the Model Context Protocol, which allows its AI agents to gather information from outside resources to better complete the tasks they're given.

"Understanding Project Details. Trae gains a good grasp of a project's specifics by looking at code repositories, information from online searches, and documents provided by users.

Developers can also set up custom rules to fine-tune the AI's behavior, making sure it handles tasks exactly as intended.

"And Smart Code Suggestions. As developers type, Trae offers intelligent code completions as it can anticipate what the developer is trying to write and automatically fill in code segments, helping speed up the writing process.

"The idea is to make the interaction feel natural, allowing developers to assign tasks or ask for help using simple commands. This approach could fundamentally change team dynamics, making AI less of a tool and more of a team member."

And so in conclusion he adds: "The arrival of free, capable AI coding agents like Trae AI isn't just another tech trend. It shows a maturing of AI into a practical aid for a highly skilled and often costly workforce. Its mix of free pricing, configurable agents, and tight privacy controls offers a low-risk way to explore agentic coding without rewriting procurement rules.

"For CTOs and engineering managers, the math is straightforward: swap a paid copilot for a free, locally hosted agent system and redirect budget to GPU credits or headcount. While AI won't be replacing entire development teams anytime soon, tools that augment their abilities, especially free ones, are certainly worth trying. If your roadmap includes AI-assisted development, but your finance team keeps asking for ROI proof, Trae may be the simplest 'yes' you can give for the entire quarter."

Okay. So I don't mean to suggest that this Trae IDE-centric AI coding system is in any way super special. Quite the contrary, in fact. I'm sure the world is already being flooded with similar and similarly powerful AI-based solutions. I just wanted to share a sample of the tool that happened to be picked by the Chinese language speaker who created this particular "VoidLink" malware. As is always the case for these sorts of things, my interest in sharing this on the podcast is giving this event, the news that this event brings, some context. And as I said at the top of the show, unfortunately, today, I truly fear that the news is worse than bad, and I am unable to find a silver lining here.

We're all familiar with the notion of asymmetric warfare, sometimes referred to as guerilla war. The use of malware, any malware, to penetrate, infect, exfiltrate, and encrypt an enterprise's resources is inherently asymmetric. One lone malicious hacker hiding somewhere, anywhere on the Internet - perhaps, literally, in his mother's basement - is able to singlehandedly attack and significantly negatively impact the national economy of the United Kingdom in one well-placed attack on Jaguar Land Rover. It's the very definition of asymmetry.

The problem with this emergence of AI, and its expected application to the empowerment of all forms of coding, is that I believe history and the evidence suggests that the bad guys will be gaining a far greater advantage from their malicious application of AI to create malware than the good guys will be gaining through their use of it to do what? It's not at all clear what the good guys can do that isn't already being done. In other words, I cannot see how the benefit from the application of AI to both sides is in any way even close to being symmetric. I believe that AI's value is extremely asymmetric here, and that the asymmetric battle that's been waged for the past decade is about to become far more asymmetric.

In years past we've observed that hacker talent encompasses a wide range, from the so-called "script kiddies" at the low end to the elite hackers at the high end. And we know that this also takes a pyramid shape, with a great many lower-end wannabe hackers at the bottom, and a much more rarified few at the top of the pile.

Recently, we've seen that the followers of this podcast have already been employing AI to create successful solutions that they would have never been able to create otherwise. And you, Leo, as a lifelong coder, could have written your newsfeed reader from scratch the old-fashioned way.

Leo: Yeah. I'd still be working on it.

Steve: So for you, yeah, exactly, Claude's AI served as a powerful accelerant. But we know from the testimony of our listeners that for many of them, who were coding-adjacent but not coders, AI has now bridged that gap to allow them to create their own functioning tools that never existed before.

So what AI has already done is completely eliminate coder-wannabe script kiddies from the low end by empowering them to author their own powerful malicious code. They no longer need to follow somebody else's script. Any mischief they can think of to get up to, an AI will happily manifest, in code, just for them. Consequently, we are almost certainly facing a forthcoming explosion in the volume and variety of malicious attacking code.

I would like to be able to imagine some form of silver lining for the defenders in this asymmetric war. But as I said, I have been unable to come up with any. What we see is an epidemic of misconfiguration and lazy configuration, communication failures and finger pointing, lingering old designs and practices, and systems that remain online despite not having received any attention for years. AI is not going to fix any of that. We also see employees in positions of trust on internal enterprise networks being tricked into clicking malicious links and inviting malware inside the house. No form of fancy AI coding is going to fix any of those things. Every single one of those is a human-factors failure. We already know how to fix every one of those things, but we haven't cared enough to do so. And there's reason to believe, I think, that we're about to pay the piper, even more fully than we have been.

A great many of the world's enterprises are sitting ducks, and entire new generations of would-be hunters who have been using slingshots have all just been up-armed with advanced cyber-rifles.

Leo: Kind of makes me want to sit down and try my hand at some malware myself.

Steve: Got a free hour?

Leo: Wow, yeah.

Steve: I mean, I don't think it's even. I think that the bad guys are going to jump on this.

Leo: Oh, yeah.

Steve: It's going to spread. They'll be sharing tips and tools and tricks, you know, within their communities.

Leo: Sure. That's true.

Steve: It's going to be a mess. And again, we know, I mean, yes, there are flaws in software. That's a problem. But those are not the stories that we're covering anymore, largely. It's big mistakes being made by enterprises, their employees, and their IT people that are just not - they're not fixing the things we already know how to fix. They're not patching servers for which there have been patches for years. And AI isn't going to help there. But AI is going to help the malware.

Leo: It's job security for us. And that's the good news. Yeah, very interesting. Very interesting.

Steve: You know, Leo, when I made the jump from three digits to four digits in my software to be able to handle this podcast, maybe it's glad that now we can go to 9999.

Leo: We might have to at this rate. Fortunately, by then it'll be our AIs doing the shows, not us. We'll be resting somewhere.

Copyright (c) 2014 by Steve Gibson and Leo Laporte. SOME RIGHTS RESERVED

This work is licensed for the good of the Internet Community under the Creative Commons License v2.5. See the following Web page for details:
<http://creativecommons.org/licenses/by-nc-sa/2.5/>